

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to explain how DNS cache poisoning works and why the original DNS design was vulnerable to it.
- By the end of this lecture, you will be able to describe how DNSSEC uses digital signatures and a chain of trust to authenticate DNS responses without encrypting them.
- By the end of this lecture, you will be able to distinguish between what DNSSEC protects and what DNS privacy technologies such as DNS over HTTPS address separately.
- By the end of this lecture, you will be able to compare site-to-site and remote-access VPN configurations and identify the appropriate use case for each.
- By the end of this lecture, you will be able to explain IPsec IKE phase negotiation, the role of Encapsulating Security Payload, and the security implications of split tunneling.
- By the end of this lecture, you will be able to articulate why a VPN is not an access control system and how zero-trust network access addresses that limitation.

Introduction

Two foundational assumptions underlie much of how cloud services communicate: that the DNS name a service resolves actually belongs to the intended destination, and that the encrypted tunnel between two endpoints is under the control of the parties who established it. When either assumption is violated, the security properties of everything built on top of those foundations are compromised — regardless of how well individual applications are secured. DNSSEC and VPNs are the controls that make those assumptions defensible rather than simply trusted.

DNS cache poisoning was a theoretical concern for years before a 2008 security researcher disclosure demonstrated a practical technique that could poison most major DNS resolver implementations in minutes without requiring a privileged network position. Following that disclosure, the DNS root zone was signed with DNSSEC, and major public resolver operators including Cloudflare and Google deployed DNSSEC validation by default. The urgency of that response reflects how foundational name resolution integrity is to every subsequent network security decision. A cloud environment with excellent TLS configuration, strong access controls, and comprehensive logging is still vulnerable to traffic redirection if DNS responses can be forged.

VPNs address a different but equally foundational concern: protecting the confidentiality and integrity of communications that traverse networks the organisation does not control. Site-to-site VPNs have become standard architecture in hybrid cloud deployments, providing persistent encrypted connectivity between on-premises infrastructure and cloud virtual private clouds. Remote-access VPNs extend that protection to individual users working from locations outside the corporate perimeter. Understanding the protocol mechanics,

the configuration decisions that affect security posture, and the limitations of VPN-based access models is essential for designing and evaluating cloud security architectures.

Core Concepts Explained

DNS Cache Poisoning and the DNSSEC Response

Definition: DNS cache poisoning is an attack in which false DNS records are injected into a resolver's cache, causing clients of that resolver to be directed to attacker-controlled IP addresses when resolving affected domain names. DNSSEC (Domain Name System Security Extensions) counters this by adding cryptographic digital signatures to DNS records, allowing resolvers to verify that responses were created by the authorised zone operator and have not been modified in transit.

Business relevance: DNS is the naming layer for virtually all cloud service communication. A poisoned DNS response can redirect API calls, authentication requests, and user traffic to attacker infrastructure without any visible indication to end users or application logs. For cloud services that depend on DNS for service discovery, database connectivity, and external API integration, DNS integrity is a prerequisite for the security of all those dependencies.

Cloud Security Practitioner relevance: A Cloud Security Practitioner should verify that DNSSEC validation is enabled on the DNS resolvers used by cloud workloads, and that any domains the organisation controls have DNSSEC signing deployed and maintained. They should also understand that DNSSEC does not encrypt DNS queries — query confidentiality requires separate technology — and ensure that distinction is reflected in security documentation and architecture decisions.

Real-world example: In 2008, security researcher Dan Kaminsky disclosed a practical DNS cache poisoning technique that exploited weaknesses in DNS transaction ID randomisation. By flooding a resolver with forged responses to queries it was actively making, an attacker could statistically guess the correct transaction ID and port combination and inject a false record before the legitimate response arrived. The attack required no privileged position on the network and could be completed in seconds to minutes against most resolver implementations of the time. The disclosure triggered an emergency coordinated patch release across DNS software vendors, followed by the signing of the DNS root zone with DNSSEC in 2010. Today, resolvers operated by Cloudflare (1.1.1.1) and Google (8.8.8.8) validate DNSSEC signatures by default, meaning clients using those resolvers receive an authentication layer on top of every DNS response they return — but only for domains that have been signed by their operators.

Risks or limitations: The best practice for DNS integrity is a two-part deployment: enable DNSSEC validation on all resolvers used by cloud workloads (so forged responses to those resolvers are rejected), and deploy DNSSEC signing on all domains the organisation controls (so other resolvers can validate responses about those domains). Both halves are necessary — signing your domain is irrelevant if the resolver does not validate, and validating is irrelevant for domains that have not been signed.

DNSSEC Chain of Trust

Definition: DNSSEC establishes trust in DNS responses through a hierarchical chain. Each signed DNS zone publishes a DNSKEY record containing its public key, and uses the corresponding private key to sign its resource records as Resource Record Signatures (RRSIGs). The parent zone validates the child's public key by publishing a Delegation Signer (DS) record containing a hash of the child's DNSKEY. The chain continues to the DNS root zone, which is signed with a root key distributed publicly and independently verifiable. A validating resolver walks this chain from the root downward, rejecting responses if any link fails.

Business relevance: The chain of trust model means that DNSSEC cannot be partially deployed for a domain — every link in the chain from the root to the specific record must be intact. A broken DS record at any parent zone level will cause DNSSEC validation to fail for all records in the child zone, regardless of how correctly the zone itself is signed. This has operational implications: zone key rollovers must be coordinated with parent zone operators to keep DS records current.

Cloud Security Practitioner relevance: When advising on DNSSEC deployment for an organisation's own domains, a Cloud Security Practitioner should ensure that the DNSSEC signing process includes a documented key rollover procedure, that DS records are updated at the registrar or parent zone operator when keys change, and that DNSSEC validation failures are monitored and alerted — a validation failure may indicate either a configuration error or an active attack.

Real-world example: A cloud-native software company deploys DNSSEC signing for their primary customer-facing domain. Twelve months later, they rotate their Zone Signing Key as a standard security practice. The zone signing process updates the DNSKEY record correctly, but the operations team does not update the corresponding DS record at the domain registrar. DNSSEC-validating resolvers including those operated by Cloudflare and Google begin returning SERVFAIL responses for all queries against the domain — effectively taking the domain offline for clients using those resolvers. The incident affects approximately 30% of the company's customer base for four hours until the DS record is updated. The post-incident action is a documented key rollover procedure that includes registrar DS record update as a mandatory step, with verification of chain validation before the rollover is considered complete.

Risks or limitations: The practice that prevents DS record desynchronisation failures is a formal key rollover procedure with an explicit verification step. After any key change, the updated chain should be validated using a DNSSEC debugger (such as the one available at dnsviz.net or Verisign's DNSSEC Debugger) before the rollover is considered complete. Monitoring for DNSSEC validation failures using resolver logs or third-party DNS monitoring services provides ongoing assurance.

DNSSEC vs DNS Privacy Technologies

Definition: DNSSEC provides authentication and integrity for DNS responses — it allows a resolver to verify that a DNS record was created by the authorised zone operator and has not been tampered with. It does not encrypt DNS records or queries. DNS over HTTPS (DoH) and DNS over TLS (DoT) are separate technologies that encrypt the communication between a DNS client and its resolver, preventing third parties from observing which domains are being queried. These are complementary technologies addressing different attack surfaces.

Business relevance: The distinction matters because organisations often assume that DNSSEC alone provides query privacy. It does not. An observer on the network between a client and its resolver can still read every DNS query even when DNSSEC is deployed, because DNSSEC signatures are transmitted in plaintext. Regulatory requirements around user privacy and data protection may require DNS query confidentiality in addition to DNS response integrity.

Cloud Security Practitioner relevance: A Cloud Security Practitioner should be able to specify when each technology is appropriate. DNSSEC validation is appropriate for all cloud workloads to protect against DNS cache poisoning. DoH or DoT are appropriate where DNS query confidentiality is required — for example, where network monitoring might reveal sensitive business information or where user privacy regulations apply to browsing behaviour.

Real-world example: A managed security service provider (MSSP) operates a cloud platform serving clients in the healthcare sector. An architecture review identifies that the platform uses a public resolver with DNSSEC validation enabled, providing protection against DNS cache poisoning. However, network traffic analysis reveals that DNS queries are transmitted in plaintext to the resolver, meaning that any network observer between the

workload and the resolver can read the hostnames being resolved — including internal service names that reveal information about the client's technology stack and data flows. The MSSP adds DNS over TLS configuration to all workloads, encrypting the resolver communication and removing the query visibility gap. DNSSEC and DoT are deployed together: DNSSEC validates the responses once they arrive, and DoT ensures the query and response exchange cannot be observed in transit.

Risks or limitations: The best practice is to deploy DNSSEC validation for response integrity and DoH or DoT for query confidentiality as complementary layers. Neither replaces the other. Organisations should document which DNS privacy technology is in use, verify that resolver endpoints support the chosen protocol, and confirm that DNS clients are configured to use the encrypted path rather than falling back to plaintext DNS when the encrypted resolver is unavailable.

Site-to-Site and Remote-Access VPN Configurations

Definition: A site-to-site VPN connects two networks through gateways at each end, creating a persistent encrypted tunnel for all traffic between the two environments. Individual workloads on either side are unaware the tunnel exists. A remote-access VPN connects individual users or devices to a network through a client application that authenticates to a VPN gateway and provides the user with an encrypted path into the internal network.

Business relevance: Site-to-site VPNs are the standard mechanism for persistent encrypted connectivity in hybrid cloud architectures, linking on-premises datacentres to cloud virtual private clouds. Remote-access VPNs enable distributed workforces to connect securely to internal systems. Both configurations protect data in transit and authenticate the endpoints establishing the tunnel, but they differ in operational characteristics, performance profiles, and the access models they support.

Cloud Security Practitioner relevance: When evaluating a hybrid cloud architecture, a Cloud Security Practitioner should assess whether site-to-site VPN connections are using strong encryption algorithms, whether IKE negotiation parameters meet the organisation's cryptographic standards, and whether VPN gateway configurations have been hardened. For remote-access VPNs, the assessment should include whether split tunneling is enabled, whether multi-factor authentication is enforced on the VPN gateway, and whether access logging is in place.

Real-world example: A financial services firm migrates their trading application to a cloud virtual private cloud while retaining their on-premises risk management systems that feed position data into the trading platform. The architecture requires persistent, encrypted connectivity between the on-premises environment and the cloud VPC. A site-to-site VPN is configured between the on-premises firewall and the cloud VPN gateway, using IPsec with IKEv2 for tunnel negotiation and AES-256-GCM for data encryption. The tunnel carries position feeds, trade confirmations, and compliance reporting data. Redundant tunnels across two internet paths provide failover. The VPN configuration is reviewed annually to confirm that the negotiated IKE parameters still meet the firm's cryptographic standards, as cipher suite support evolves over time and weak algorithm selections can persist in configurations that were not updated during software upgrades.

Risks or limitations: The practice that maintains VPN security over time is periodic cryptographic parameter review. IKE negotiation can fall back to weaker algorithms if both ends of the tunnel list stronger options but one side's software is updated without updating the preferred algorithm order. Annual review of negotiated tunnel parameters — not just the configured options — ensures that actual encryption strength reflects organisational requirements.

IPsec, Split Tunneling, and VPN Access Model Limitations

Definition: IPsec is the protocol suite underpinning most enterprise and cloud VPN deployments. It uses Internet Key Exchange (IKE) in two phases: Phase 1 establishes a secure management channel; Phase 2 negotiates encryption parameters for the data tunnel. Encapsulating Security Payload (ESP) provides encryption and authentication for data in transit. Split tunneling is a VPN configuration option where only traffic destined for the internal network routes through the encrypted tunnel; internet-bound traffic bypasses it. Traditional VPNs are not access control systems — authenticated tunnel establishment typically grants broad network access.

Business relevance: Split tunneling reduces VPN gateway load and improves end-user performance, but directs internet traffic outside corporate security controls, preventing inspection of potentially malicious outbound connections. In regulated environments, the inability to inspect all user traffic is often a compliance concern. The broader VPN access model limitation — that a single authentication grants broad network access — is a significant risk in environments where an attacker or compromised user account could move laterally once connected.

Cloud Security Practitioner relevance: A Cloud Security Practitioner should assess split tunneling policies against the organisation's security and regulatory requirements, and should evaluate whether traditional VPN access models are appropriate for the access sensitivity of the resources being protected. For environments requiring more granular access control, zero-trust network access (ZTNA) should be evaluated as an alternative or supplement.

Real-world example: A global consulting firm deploys remote-access VPN for 3,000 employees working from home. Split tunneling is enabled by default to reduce load on the central VPN gateway. During a security assessment, the assessor demonstrates that a compromised employee device can use the VPN connection to reach internal systems including file servers and internal APIs, while the device simultaneously makes unmonitored outbound connections to attacker infrastructure through the local internet connection. The device is effectively a bridge between the external attacker and the internal network. The firm implements two changes: split tunneling is disabled for users accessing sensitive internal systems (routing all traffic through the VPN and corporate inspection proxies), and the architecture team begins evaluating a ZTNA solution that would replace broad VPN network access with per-application access grants verified on every connection, rather than once at tunnel establishment.

Risks or limitations: The best practice is to disable split tunneling for users with access to sensitive resources, enforce multi-factor authentication on VPN gateways, implement access logging at the VPN gateway and on internal systems, and evaluate whether ZTNA is more appropriate than traditional VPN for environments where lateral movement risk is a primary concern.

Practical Applications

The following scenarios demonstrate how Cloud Security Practitioners apply DNSSEC and VPN knowledge in real organisational contexts.

Assessing DNS Security for a Cloud Service Migration

A Cloud Security Practitioner is conducting a pre-migration security assessment for a financial services organisation moving their customer authentication service to a cloud platform. The assessment includes a DNS security review. The practitioner discovers that the organisation's customer-facing domain has DNSSEC signing deployed at the zone level, but the DNS resolvers used by internal cloud workloads are configured to use the cloud provider's default resolver with DNSSEC validation disabled. This means that the organisation's own

workloads could receive forged DNS responses pointing to malicious infrastructure, even though external clients resolving the domain benefit from DNSSEC signing. The practitioner documents this as a high-severity finding and recommends enabling DNSSEC validation on all internal resolvers as a pre-migration requirement, not a post-migration improvement. The distinction between signing (protecting how others resolve your domain) and validation (protecting how your workloads resolve others' domains) is a common gap in organisational DNSSEC deployments, and addressing both halves is necessary for complete DNS integrity coverage.

Designing a Hybrid Cloud VPN Architecture for a Regulated Workload

A Cloud Security Practitioner is advising on the network architecture for a hybrid cloud deployment that will process data regulated under national data residency requirements. On-premises systems will feed data to cloud workloads for processing, and processed results will return to the on-premises environment. The practitioner specifies a site-to-site VPN using IPsec with IKEv2, AES-256 encryption, and SHA-384 for integrity. The VPN gateway logs all tunnel establishment and teardown events, and the configuration is reviewed against the organisation's cryptographic standards document. Redundant tunnels terminate on geographically separated cloud VPN gateway instances to ensure availability. The practitioner also documents the IKE negotiation parameters in the architecture decision record, noting that these parameters must be reviewed when either side's VPN software is upgraded, because software updates sometimes change default algorithm preferences in ways that affect negotiated tunnel strength without generating visible alerts. This documentation ensures that the cryptographic standard is actively maintained rather than set and forgotten.

Evaluating a Zero-Trust Migration from Traditional VPN

A technology company with 800 remote employees is evaluating whether to replace their remote-access VPN with a zero-trust network access (ZTNA) solution. The Cloud Security Practitioner involved in the evaluation documents the key architectural difference: the existing VPN, once authenticated, places users inside a network segment with access to dozens of internal services they may not need for their specific role. A ZTNA solution would authenticate users and their devices before each application connection, grant access only to the specific application requested, and re-evaluate trust continuously rather than once at session establishment. The practitioner maps the current VPN's broad access grants against actual user role requirements and finds that 70% of users have access to significantly more internal systems than their job function requires — a classic case of excessive implicit trust. The ZTNA evaluation includes a pilot with one department, measuring impact on user experience and support volume, before a broader rollout. The practitioner notes that ZTNA and VPN can coexist during transition, with VPN retained for legacy applications that cannot support ZTNA integration while the migration proceeds.

Best Practices

- **Deploy DNSSEC signing on all organisational domains and enable DNSSEC validation on all DNS resolvers used by cloud workloads.** Both halves of DNSSEC deployment are necessary. Signing your domain protects clients who resolve it; validation protects your workloads when they resolve other domains. Verify both are in place during any DNS architecture review, and document which domains are signed and which resolvers are configured to validate.
- **Implement DNS over HTTPS or DNS over TLS alongside DNSSEC for environments where query confidentiality is required.** DNSSEC authenticates responses but leaves queries readable by network observers. DoH or DoT encrypts the client-to-resolver communication. Determine whether query confidentiality is a regulatory or security requirement for the environment and deploy the appropriate technology accordingly, ensuring that fallback to plaintext DNS is not permitted.

- **Document IPsec VPN cryptographic parameters and review them annually, especially after software upgrades.** IKE negotiation parameters — encryption algorithms, integrity algorithms, Diffie-Hellman groups — can drift toward weaker options during software upgrades if default algorithm lists change. Record the negotiated parameters (not just the configured options) at initial deployment and after each upgrade, and compare against the organisation's approved cryptographic standards.
- **Disable split tunneling for users with access to sensitive resources and enforce MFA on all VPN gateways.** Split tunneling allows attacker access to the user's device to bridge into the internal network through an active VPN connection. For any role with access to sensitive systems, all traffic should route through the VPN and corporate inspection controls. Multi-factor authentication on the VPN gateway ensures that stolen credentials alone are insufficient to establish a tunnel.
- **Evaluate ZTNA as an alternative to broad-network VPN access for environments where lateral movement risk is a primary concern.** Traditional VPNs grant broad network access on authentication — a useful property for general connectivity but a significant risk when a user account or device is compromised. ZTNA grants per-application access verified on each connection, limiting the blast radius of any credential compromise. Evaluate which model is appropriate based on the sensitivity of resources being accessed and the regulatory requirements for access logging and least-privilege enforcement.

Common Mistakes and Misconceptions

Misconception: Deploying DNSSEC signing on the organisation's own domains without enabling DNSSEC validation on internal resolvers, assuming signing alone is sufficient.

Correct approach: DNSSEC signing and validation are independent. Signing protects clients who resolve your domain from receiving forged responses. Validation protects your workloads when they resolve any domain. Both must be deployed for complete coverage. The best practice is to verify both in every DNS architecture review.

Misconception: Assuming that DNSSEC provides query confidentiality, and concluding that DNS over HTTPS or DNS over TLS is therefore unnecessary.

Correct approach: DNSSEC provides authentication and integrity only. DNS queries are transmitted in plaintext even when DNSSEC is fully deployed. For query confidentiality, DNS over HTTPS or DNS over TLS must be deployed separately. These are complementary controls addressing different attack surfaces.

Misconception: Treating a VPN as an access control system and relying on VPN authentication as the primary mechanism for limiting what authenticated users can reach.

Correct approach: Traditional VPNs authenticate tunnel establishment but typically grant broad network access once authenticated. Access control within the network must be enforced separately through firewall rules, security groups, and application-level authentication. For environments requiring fine-grained access control, zero-trust network access provides per-application access grants rather than network-level access.

Misconception: Setting IPsec VPN cryptographic parameters at initial deployment and not reviewing them when VPN software is upgraded.

Correct approach: Software upgrades can change default algorithm preferences and accepted cipher suites, causing IKE negotiation to select weaker parameters than were configured at initial deployment. The practice that prevents cryptographic drift is annual review of negotiated tunnel parameters — not just configured options — against the organisation's current cryptographic standards.

table: DNSSEC and VPN Security Decision Reference

Use this reference table to quickly identify which technology addresses which threat, and what verification action confirms the control is in place.

Threat / Requirement	Relevant Technology	Key Configuration	Verification Method
DNS response forgery / cache poisoning	DNSSEC validation	Enable validation on all resolvers; sign all organisational zones	Query a signed domain through the resolver and check for AD (Authenticated Data) flag in response
DNS query observation by network observers	DNS over HTTPS (DoH) or DNS over TLS (DoT)	Configure resolvers to use DoH/DoT endpoints; disable plaintext DNS fallback	Capture network traffic and confirm DNS queries are not visible as plaintext
DNSSEC key rollover causing chain break	DS record management process	Update DS record at registrar/parent before completing rollover	Validate chain using dnsviz.net or equivalent after each key rotation
Unencrypted connectivity between on-premises and cloud	Site-to-site IPsec VPN	IKEv2, AES-256, SHA-384; redundant tunnels; annual crypto review	Inspect negotiated SA parameters using VPN gateway logs or IKE debugging
Unprotected remote user traffic	Remote-access VPN with MFA	MFA enforced; split tunneling disabled for sensitive users; access logging enabled	Attempt VPN connection without MFA token; confirm failure
Broad network access post-VPN authentication	Zero-trust network access (ZTNA)	Per-application access grants; continuous re-evaluation; device posture checks	Verify that authenticated VPN/ZTNA users can only reach explicitly permitted applications

How to use this: This table maps threats to controls and verification steps. Use it during architecture reviews, security assessments, and pre-migration checklists to confirm that each threat category has a named control and a measurable verification action.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A security engineer enables DNSSEC signing on the organisation's primary domain. After deployment, a DNSSEC-aware resolver reports that all queries for the domain return with the Authenticated Data (AD) flag set. Three months later, the team rotates the Zone Signing Key as a standard security practice. Following the rotation, clients using DNSSEC-validating resolvers receive SERVFAIL responses for all queries on the domain. What is the most likely cause?

- A) A. The new Zone Signing Key is using a stronger algorithm that DNSSEC-validating resolvers do not yet support.
- B) B. The Delegation Signer (DS) record at the parent zone was not updated to reflect the new Zone Signing Key, breaking the chain of trust.
- C) C. DNSSEC validation must be disabled and re-enabled on all resolvers after a Zone Signing Key rotation.
- D) D. The Resource Record Signatures (RRSIGs) generated with the new key have a shorter validity period than the old key's signatures.

Answer: B. The Delegation Signer (DS) record at the parent zone was not updated to reflect the new Zone Signing Key, breaking the chain of trust.

Q2. A cloud security architect is reviewing a proposal to deploy DNSSEC on the organisation's internal DNS resolvers to protect cloud workloads. The proposal states that since the organisation has already signed its own domain with DNSSEC, deploying validation on internal resolvers is redundant. Which statement correctly evaluates this reasoning?

- A) A. The reasoning is correct — signing the domain provides protection in both directions, so validation adds no additional security.
- B) B. The reasoning is incorrect — signing protects others who resolve your domain, while validation protects your workloads when they resolve other domains. Both are needed.
- C) C. The reasoning is partially correct — validation is only necessary if the organisation's workloads resolve domains outside the organisation's own namespace.
- D) D. The reasoning is incorrect — DNSSEC validation must be deployed before DNSSEC signing for the chain of trust to function.

Answer: B. The reasoning is incorrect — signing protects others who resolve your domain, while validation protects your workloads when they resolve other domains. Both are needed.

Q3. An organisation uses a remote-access VPN with split tunneling enabled for all 500 remote employees. A security review identifies that split tunneling should be disabled for employees with access to systems containing regulated financial data. What is the primary security justification for disabling split tunneling for these users?

- A) A. Split tunneling prevents DNSSEC validation from functioning correctly on the remote device.
- B) B. With split tunneling enabled, internet-bound traffic from the remote device bypasses corporate security inspection, and a compromised device could bridge attacker access to the internal network through the active VPN connection.
- C) C. Split tunneling reduces VPN gateway capacity and can cause the gateway to fail under load, exposing internal resources.

D) D. Regulatory frameworks for financial data require all network traffic to be encrypted, and split tunneling means some traffic is not encrypted.

Answer: B. With split tunneling enabled, internet-bound traffic from the remote device bypasses corporate security inspection, and a compromised device could bridge attacker access to the internal network through the active VPN connection.

Q4. A financial institution uses a site-to-site IPsec VPN to connect their on-premises trading systems to a cloud virtual private cloud. During an annual security review, the practitioner inspects the negotiated IKE Security Association and finds that the tunnel is using 3DES encryption and SHA-1 for integrity — significantly weaker than the AES-256 and SHA-384 specified in the original configuration. What is the most likely explanation?

- A) A. The cloud VPN gateway automatically downgrades encryption to match the capacity of the on-premises device.
- B) B. A VPN software upgrade on one side changed the default algorithm priority order, causing IKE negotiation to select weaker common algorithms rather than the originally specified strong ones.
- C) C. The site-to-site tunnel is functioning correctly — 3DES is the required algorithm for IPsec in financial services environments.
- D) D. SHA-1 was automatically selected because the VPN certificate uses SHA-1 as its signing algorithm.

Answer: B. A VPN software upgrade on one side changed the default algorithm priority order, causing IKE negotiation to select weaker common algorithms rather than the originally specified strong ones.

Q5. A practitioner is comparing DNSSEC, DNS over HTTPS (DoH), and DNS over TLS (DoT) for deployment in a cloud environment that handles healthcare data. Which statement correctly describes the relationship between these technologies?

- A) A. DNSSEC, DoH, and DoT all provide equivalent protection and only one needs to be deployed.
- B) B. DNSSEC provides query confidentiality, while DoH and DoT provide response authentication — the two technologies are interchangeable.
- C) C. DNSSEC provides response authentication and integrity; DoH and DoT provide query confidentiality by encrypting DNS communication. They address different threats and can be deployed together.
- D) D. DoH and DoT supersede DNSSEC because they encrypt both queries and responses, making DNSSEC unnecessary.

Answer: C. DNSSEC provides response authentication and integrity; DoH and DoT provide query confidentiality by encrypting DNS communication. They address different threats and can be deployed together.

Reflection Questions

1. The 2008 Kaminsky DNS disclosure triggered an emergency coordinated response across the DNS industry. What does this incident suggest about the relationship between academic security research and operational security deployment timelines?
2. DNSSEC signing and validation are independent deployments that must both be in place for complete DNS security coverage. What organisational or operational factors might lead a team to deploy one without the other?
3. The lecture describes split tunneling as a performance optimisation with a security cost. How would you approach advising a business that insists on split tunneling for all employees due to VPN gateway capacity constraints?

4. Zero-trust network access is presented as addressing a fundamental limitation of traditional VPN architecture. What are the practical migration challenges an organisation would face when moving from VPN to ZTNA for a heterogeneous workforce?
5. IPsec cryptographic parameters can drift toward weaker values over time through software upgrades without generating visible alerts. What monitoring or audit mechanisms would you put in place to detect cryptographic drift in VPN configurations?

Key Takeaways

- DNS cache poisoning allows attackers to redirect traffic at the naming layer, affecting all services that depend on DNS for address resolution.
- DNSSEC protects against DNS response forgery through digital signatures and a chain of trust from the DNS root zone downward — it does not encrypt DNS queries.
- DNSSEC deployment requires both signing organisational domains and enabling validation on resolvers: each half protects a different direction of name resolution.
- The 2008 Kaminsky disclosure accelerated practical DNSSEC adoption; major resolvers including Cloudflare and Google now validate DNSSEC by default.
- DNS over HTTPS and DNS over TLS encrypt DNS queries, providing confidentiality that DNSSEC does not — the two technologies are complementary, not alternatives.
- Site-to-site VPNs provide persistent encrypted connectivity for hybrid cloud architectures; remote-access VPNs extend encryption to individual users.
- IPsec uses IKE in two phases for tunnel negotiation; annual review of negotiated parameters is essential because software upgrades can silently downgrade cryptographic strength.
- Split tunneling improves performance but bypasses corporate security inspection for internet-bound traffic and enables device-bridging attacks on internal networks.
- Traditional VPNs are not access control systems — authenticated tunnel establishment grants broad network access; ZTNA addresses this by providing per-application access grants verified continuously.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Check whether DNSSEC validation is enabled on the DNS resolvers used by your cloud workloads by querying a known-signed domain (such as cloudflare.com) and verifying the AD flag in the response using dig or an equivalent tool.
7. Verify whether your organisation's own domains have DNSSEC signing deployed using a DNSSEC validation checker such as dnsviz.net, and identify any chain validation errors.
8. Review the negotiated IKE Security Association parameters on any site-to-site VPN connections in your environment and compare them against the organisation's approved cryptographic standards document.
9. If your organisation uses remote-access VPN with split tunneling enabled, identify which user roles have access to sensitive or regulated systems and document the case for disabling split tunneling for those roles.